

Mining Remote Operations and Industrial-IoT Intrusion Analytics

Security analytics for detecting anomalous behaviour in mining remote operations,
delivered through a working prototype

Topic T08 · Project Implementation Plan and Working Prototype

Member A	222093471 · Sophia Kalume · Data and Modelling Lead
Member B	215103815 · Lasarus Shithindi · Security Engineering and Intelligence Lead
Milestone	2 of 4 · weight 40% of the capstone mark
Due	20 September 2026
Submitted	20 September 2026
Institution	Namibia University of Science and Technology

Contents

1. Executive summary	3
2. Alignment with the approved Project Charter	4
2.1 Objectives and analytics questions	4
2.2 Data sources	4
2.3 Analytical methods	5
2.4 Scope	5
3. Architecture and data flow	6
4. Data inventory, dictionary, cleaning log and quality checks	8
4.1 Inventory and minimum-data compliance	8
4.2 Data dictionary	8
4.3 Cleaning and transformation log	9
4.4 Quality checks	10
5. Exploratory analysis, baselines and security hypotheses	11
5.1 Initial security hypotheses	12
6. Supervised model and anomaly/behavioural model	13
6.1 Supervised intrusion detection	13
6.2 Anomaly and behavioural methods	14
7. Incident timeline, access findings and response logic	17
7.1 Access and identity analytics	17
7.2 Selected case	17
7.3 Response logic	18
8. Security intelligence requirements, enrichment and first products	19
9. Simulation design and preliminary comparative results	21
10. Text-mining and NLP workflow and preliminary outputs	23
11. Predictive risk method and adversarial test cases	25
11.1 Daily risk score	25
11.2 Early warning	25
11.3 Adversarial and robustness tests	25
12. Working prototype, test cases, known defects and backlog	27
12.1 Prototype	27
12.2 Test cases	29
12.3 Known defects and limitations	29
12.4 Implementation backlog	30
13. Repository, environment and contribution evidence	31
14. Updated risk register and deviations from the charter	32
14.1 Declared deviations	32
15. Implementation plan to Milestones 3 and 4	33
15.1 Priorities for Milestone 3	34
16. Limitations, ethics and AI assistance	34
Appendix A. Requirement coverage C1-C10	35
Appendix B. Experiment log	35
Appendix C. Figure and file index	37

1. Executive summary

This milestone reports an implemented security analytics solution for the T08 mining remote-operations scenario, not a plan for one. The pipeline runs end to end from raw data files to a compliance checklist in 1 seconds across 4 stages, and an analyst-facing console presents the results for decision-making. Every figure quoted in this document is read directly from the files the pipeline writes.

The analysis covers **635,833 records** across 13 files and five source families. Roughly 612,519 of those records are real research data (ToN_IoT captures from UNSW Canberra and the MITRE ATT&CK for ICS corpus) and 23,314 are synthetic data generated by documented rules for the identity/access and maintenance-text components, which the charter and the capstone specification both permit.

The main results are:

- **Supervised detection.** A random forest separates attack from normal network flows with F1 0.9987 (precision 0.9987, recall 0.9987) on a held-out 30 per cent, after 20,569 duplicate rows were removed to prevent leakage. Attack-family identification reaches macro-F1 0.9645. A Modbus telemetry classifier reaches F1 0.9887.
- **Anomaly detection.** On remote-access behaviour, an Isolation Forest reaches ROC-AUC 0.997 against the behaviour patterns that were deliberately injected into the synthetic log, flagging 56 of 2,792 user-days at the chosen threshold. On the network flows the same method scores 0.28 when run fully unsupervised and 0.72 when fitted on known-good traffic; that contrast is reported as a finding rather than hidden.
- **Investigation.** Case ranking selected account vend069 (vendor_technician), with 16 privileged actions of which 16 had no multi-factor authentication, touching 8 assets. The timeline holds 202 rows, each citing its evidence and its linkage basis.
- **Simulation.** Five control scenarios at 5,000 Monte Carlo runs each. The chance of an intrusion reaching the OT zone falls from 54% under current controls to 19% with enforced MFA and 10% with the combined package. The ranking is stable across a sensitivity sweep of the assumed probabilities.
- **Text mining.** 677 unstructured records processed, with classification, indicator extraction scored against an answer key (precision 0.972, recall 0.997) and ATT&CK enrichment.
- **Predictive risk and robustness.** A six-component daily risk score separates the injected behaviour with ROC-AUC 0.988. Four families of adversarial and robustness tests were run; the largest degradation is a fall of 0.23 in F1 when half the collected fields are lost.

Status of the data. The ToN_IoT captures are real research data from a laboratory testbed, used here as a proxy for mining IIoT and OT behaviour. The remote-access log, the maintenance tickets, the asset inventory and the user directory are synthetic, produced by seeded generators whose rules are in the repository. Four abnormal access patterns were injected on purpose and recorded in a ground-truth column, so all detection results in this document mean that the method found behaviour we planted. No claim is made anywhere that a real intrusion was discovered.

2. Alignment with the approved Project Charter

The charter defined the problem as “identifying how security analytics can be used to detect and prioritise anomalous IIoT, network and remote-user behaviour in a simulated mining remote-operations environment”. That statement is unchanged. This section maps each charter commitment to what now exists.

2.1 Objectives and analytics questions

Charter objective or question	Measure of completion (charter)	Status at Milestone 2
Objective 1: prepare and integrate IIoT, network-flow and remote-user activity data	Cleaned datasets, documented preprocessing steps, identified analytical features	Met. 13 sources cleaned through a logged pipeline (37 recorded actions); engineered features for flows, telemetry and access behaviour.
Objective 2: develop a prototype that detects and prioritises anomalous IIoT, network and remote-user behaviour	Working anomaly/behaviour process, risk prioritisation, functioning dashboard	Met. Isolation Forest and seven behaviour rules feed a risk score and an eight-view Streamlit console.
Question 1: which IIoT and network behaviours deviate from normal patterns?	EDA and anomaly results identifying and ranking anomalous events	Answered with baselines per sensor, per service and per role, plus ranked anomaly scores; see sections 5 and 6.
Question 2: can remote-user activity identify unusual or suspicious access?	Behavioural indicators and identified anomalous user activities supported by evidence	Answered. 176 rule alerts, each citing event identifiers, plus a scored user-day ranking; see section 7.
Question 3: how can detected anomalies be prioritised for investigation?	Documented risk-scoring approach and ranked events in the prototype	Answered with a six-component score, four bands tied to actions, and a prioritised watchlist in the console; see section 11.

Table 1. Charter objectives and questions against the state of the implementation.

2.2 Data sources

The charter listed four source types with volumes “to be determined after dataset selection”. Selection is now complete.

Charter source	Charter key fields	What was actually used	Records	Provenance
IIoT telemetry	Timestamp, device ID, sensor readings, operating status	ToN_IoT telemetry, 7 sensor types	401,119	Public research data
Network-flow data	Timestamp, source, destination, protocol, port, packets, bytes, duration	ToN_IoT Zeek flow records	211,043	Public research data; no timestamp column in this release
Remote-user activity	User ID, timestamp, login/logout, source, device, access/action	Generated remote-access log	22,686	Synthetic, seeded, documented generator
Maintenance/incident text	Timestamp, equipment ID, event description, category	Generated ticket corpus and MITRE ATT&CK for ICS descriptions	677	Synthetic tickets; ATT&CK corpus is real and public
(added) Asset and account context	Asset, site, zone, criticality, protocol, privilege	Asset inventory and user directory	308	Synthetic; required by C2 to interpret findings operationally

Table 2. Charter data sources mapped to the datasets actually used.

2.3 Analytical methods

Three charter entries were marked TBC or conditional. All three are now implemented, and two components were deliberately extended beyond the charter because the data supported more than was originally promised.

Component	Charter proposal	Change	What was implemented
Baseline / EDA	Python, pandas, NumPy, visualisation	As planned	Baselines per sensor, service, role and user; eight exploratory figures
Supervised ML	TBC in the charter	Specified and implemented	Logistic regression, decision tree and random forest compared by cross-validated F1
Unsupervised / UBA	Isolation Forest and rule-based user behaviour analysis	As planned, extended	Isolation Forest, Local Outlier Factor, DBSCAN peer groups and seven behaviour rules
Incident investigation	Event filtering, correlation and timeline analysis	As planned	Evidence-ranked case selection and a 202-row correlated timeline
Security intelligence	Risk scoring and event prioritisation	As planned, extended	Five intelligence requirements, ATT&CK enrichment, operational watchlist and an executive brief
Simulation	Simple segmented-network scenario simulation	Extended	Five scenarios including segmentation, MFA and monitoring, with sensitivity analysis
Text mining / NLP	TBC, conditional on suitable data	Implemented	TF-IDF classification, indicator extraction with an answer key, NMF topics, ATT&CK similarity enrichment
Predictive / adversarial	Limited risk-pattern analysis	Extended	Interpretable risk score, next-day early warning and four adversarial test families
Prototype / dashboard	Python, Streamlit, Plotly	As planned	Eight-view analyst console plus a reproducible notebook

Table 3. Charter analytical methods against the implementation, with changes marked.

2.4 Scope

The scope boundaries in the charter hold. No live mining infrastructure, physical equipment, real credentials or confidential data were used, and no penetration testing of any kind was performed. All work was carried out on public research datasets and on synthetic data generated for the exercise.

3. Architecture and data flow

The charter's architecture ran from three data sources through ingestion and cleaning to anomaly detection and user-behaviour analytics, then risk scoring, a prototype and a segmentation simulation. The implemented architecture keeps that spine and adds the stages the specification requires: supervised modelling, investigation, text mining, intelligence products and adversarial testing. Every stage in the diagram corresponds to a script in `src/` and to output files a marker can open; the diagram is generated from that list, so it cannot drift away from the code.

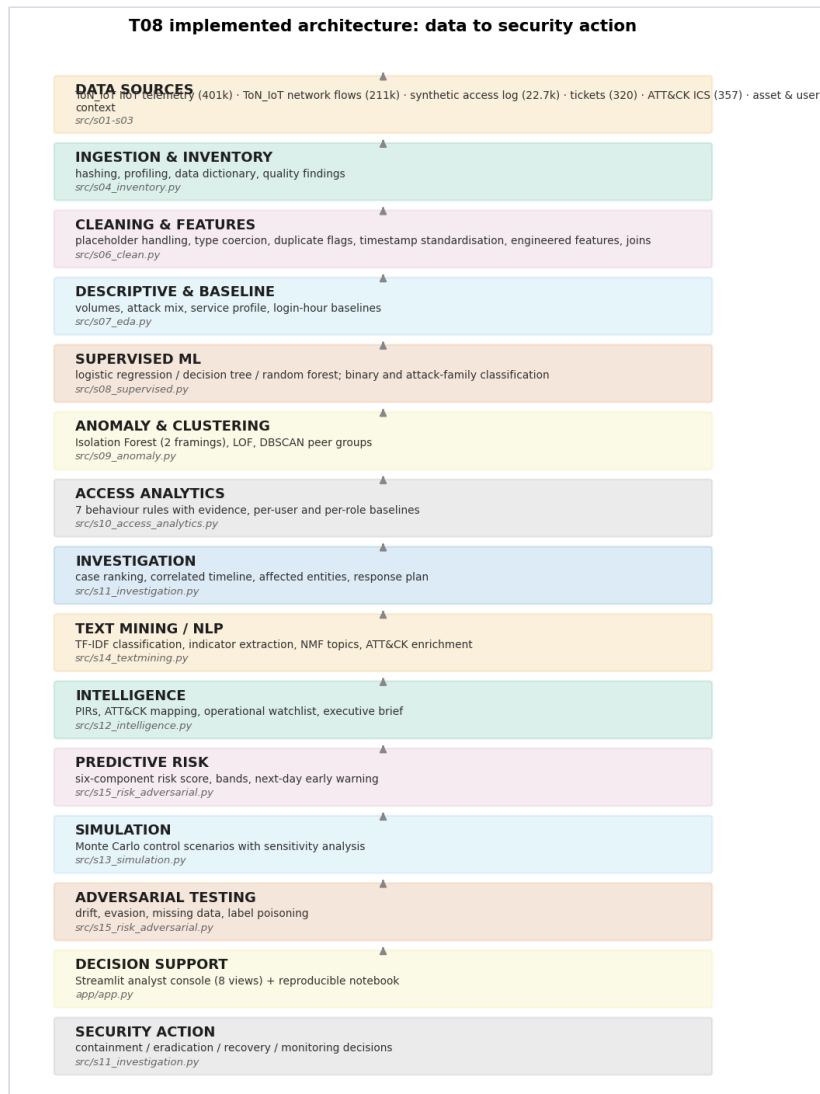


Figure 26. Implemented architecture. Each block names the script that implements it.

stage	implemented_in	evidence_present
DATA SOURCES	<code>src/s01-s03</code>	2/2
INGESTION & INVENTORY	<code>src/s04_inventory.py</code>	2/2
CLEANING & FEATURES	<code>src/s06_clean.py</code>	2/2
DESCRIPTIVE & BASELINE	<code>src/s07_edu.py</code>	2/2
SUPERVISED ML	<code>src/s08_supervised.py</code>	1/1
ANOMALY & CLUSTERING	<code>src/s09_anomaly.py</code>	1/1
ACCESS ANALYTICS	<code>src/s10_access_analytics.py</code>	1/1
INVESTIGATION	<code>src/s11_investigation.py</code>	1/1

stage	implemented_in	evidence_present
TEXT MINING / NLP	src/s14_textmining.py	1/1
INTELLIGENCE	src/s12_intelligence.py	1/1
PREDICTIVE RISK	src/s15_risk_adversarial.py	1/1
SIMULATION	src/s13_simulation.py	1/1
ADVERSARIAL TESTING	src/s15_risk_adversarial.py	1/1
DECISION SUPPORT	app/app.py	1/1
SECURITY ACTION	src/s11_investigation.py	1/1

Table 4. Architecture stages with the script that implements each one and the count of expected evidence files found on disk.

Data moves in one direction. Raw files are read but never written; cleaned tables are written to data/processed/ in Parquet; every analytical stage writes CSV or JSON into outputs/tables/; the console and the notebook read those outputs and never recompute them. This separation is what makes the prototype reproducible: the dashboard cannot show a number that is not in a file.

4. Data inventory, dictionary, cleaning log and quality checks

4.1 Inventory and minimum-data compliance

dataset	rows	columns	data_status	project_role	duplicate_rows	labelled
iot_fridge	59944	7	public research dataset	IIoT telemetry	8901	True
iot_garage_door	59587	7	public research dataset	IIoT telemetry	38836	True
iot_gps_tracker	58960	7	public research dataset	IIoT telemetry	0	True
iot_modbus	51106	9	public research dataset	IIoT telemetry (OT protocol)	19744	True
iot_motion_light	59488	7	public research dataset	IIoT telemetry	28629	True
iot_thermostat	52774	7	public research dataset	IIoT telemetry	1154	True
iot_weather	59260	8	public research dataset	IIoT telemetry	0	True
network_flow	211043	44	public research dataset	Network activity	20569	True
access_log	22686	18	SYNTHETIC	Identity/access activity	0	False
asset_inventory	194	11	SYNTHETIC	Asset/device context	0	False
user_directory	114	7	SYNTHETIC	User/account context	0	False
tickets	320	10	SYNTHETIC	Unstructured maintenance/incident text	0	True
attack_ics_text	357	11	public, attribution required	Unstructured threat-intelligence text	0	False

Table 5. Data inventory. Full provenance, SHA-256 hashes and time coverage are in outputs/tables/data_inventory.csv.

requirement	measured	threshold	status
At least three distinct security data sources	5 source families: IIoT telemetry, network flows, remote-access log, ticket text, ATT&CK ICS text (plus asset and user context)	≥ 3	MET
At least 5,000 combined event/transaction records	635,833 records across 13 files	$\geq 5,000$	MET
At least one labelled dataset (recommended $\geq 1,000$ records)	IIoT telemetry 401,119 labelled rows; network flows 211,043 labelled rows	$\geq 1,000$	MET
At least one unlabelled/semi-labelled dataset for anomaly or behavioural work	Synthetic remote-access log 22,686 events with no operational label (injected patterns held back as ground truth only)	≥ 1 dataset	MET
At least 200 unstructured text records	677 records (320 tickets + 357 ATT&CK ICS descriptions)	≥ 200	MET
Documented asset/user/device/account/service context	194 assets and 114 user accounts with site, zone, criticality, protocol and privilege attributes	documented	MET

Table 6. Minimum data expectations from specification 5.1, checked against the loaded data.

4.2 Data dictionary

Every column in every dataset was profiled and classified by the role it plays in the analysis: timestamp, user account, device or asset, IP address, network field, authentication or access field,

security label, unstructured text, numeric or categorical. The full dictionary lists 153 columns and is supplied as `outputs/tables/data_dictionary.csv` and `docs/member_a_data_dictionary.md`. The classification is what demonstrates requirement C2 concretely: identity and access fields, network and OT fields and asset context all exist in the data rather than only in the proposal.

4.3 Cleaning and transformation log

37 cleaning actions were recorded, each with the dataset, the action, the detail, the reason and the row counts before and after. Four decisions are worth stating because a marker is likely to ask about them:

- **Zeek's '-' placeholder is treated as missing, not as a category.** Left as text it becomes one of the strongest predictors in the model, and an entirely artificial one.
- **Duplicates are flagged rather than deleted.** The flag excludes them from model training and testing, but the rows remain in the stored data so no evidence is destroyed.
- **Missing telemetry values are not imputed.** A gap in a sensor feed is a gap; an invented reading would teach the model a pattern that never happened.
- **Country codes use ISO-3.** The original ISO-2 code for Namibia, 'NA', was silently read as a missing value and made every user-day look foreign. This was found, fixed and covered by a regression test.

dataset	action	detail	reason
iot_fridge	strip_whitespace_bom	all object columns	raw files contain a BOM and padded values such as ' off '
iot_fridge	drop_redundant_columns	date, time	both duplicate the information already held in ts
iot_fridge	standardise_category	temp_condition	case and spacing varied between records
iot_fridge	flag_exact_duplicates	8901 rows flagged	identical ts and values; kept but flagged so models can exclude them without deleting evidence
iot_garage_door	strip_whitespace_bom	all object columns	raw files contain a BOM and padded values such as ' off '
iot_garage_door	drop_redundant_columns	date, time	both duplicate the information already held in ts
iot_garage_door	coerce_numeric	sphone_signal: 35000 values to NaN	non-numeric text found in a measurement column
iot_garage_door	standardise_category	door_state	case and spacing varied between records
iot_garage_door	flag_exact_duplicates	38836 rows flagged	identical ts and values; kept but flagged so models can exclude them without deleting evidence
iot_garage_door	retain_missing	sphone_signal: 35000 NaN	gaps are treated as missing telemetry, not imputed, so that the model cannot learn from invented readings
iot_gps_tracker	strip_whitespace_bom	all object columns	raw files contain a BOM and padded values such as ' off '
iot_gps_tracker	drop_redundant_columns	date, time	both duplicate the information already held in ts
iot_gps_tracker	flag_exact_duplicates	0 rows flagged	identical ts and values; kept but flagged so models can exclude them without deleting evidence
iot_modbus	strip_whitespace_bom	all object columns	raw files contain a BOM and padded values such as ' off '
iot_modbus	drop_redundant_columns	date, time	both duplicate the information already held in ts
iot_modbus	flag_exact_duplicates	19744 rows flagged	identical ts and values; kept but flagged so models can exclude them without deleting evidence

Table 7. Extract from the cleaning log (first 16 of 37 actions). The full log is `outputs/tables/cleaning_log.csv`.

4.4 Quality checks

10 quality findings were recorded automatically before cleaning: 6 duplicate rows, 2 high missingness, 2 constant column. Sixteen columns in the flow data are more than 97 per cent empty; they are retained in the file for investigation but excluded from model features.

5. Exploratory analysis, baselines and security hypotheses

Before any model was fitted, the question asked was what normal looks like in each source. Baselines were computed per sensor and measure, per network service, per role and per user, and are stored as `outputs/tables/baseline_*.csv`.

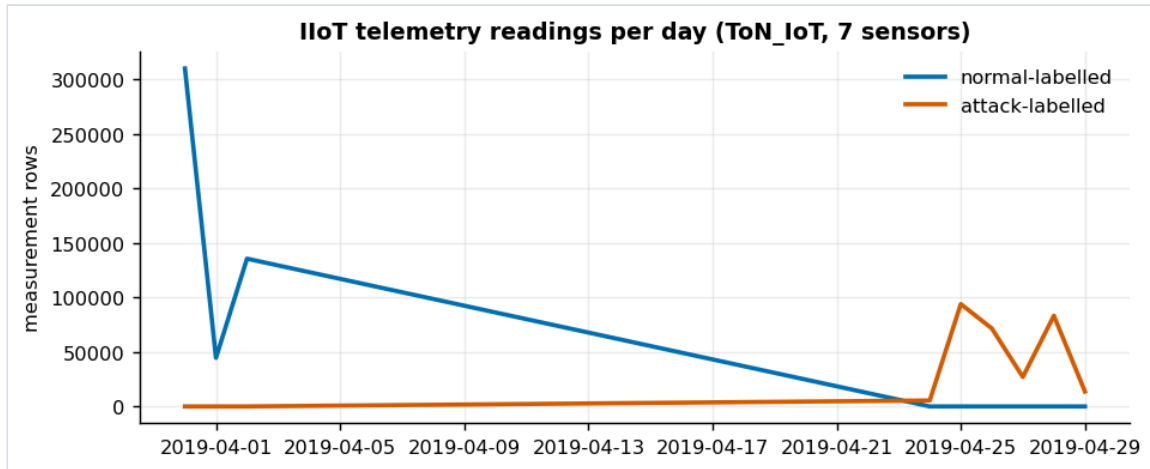


Figure 1. IIoT telemetry volume per day, separated by label. Attack-labelled activity in this capture is concentrated in the last week of April 2019.

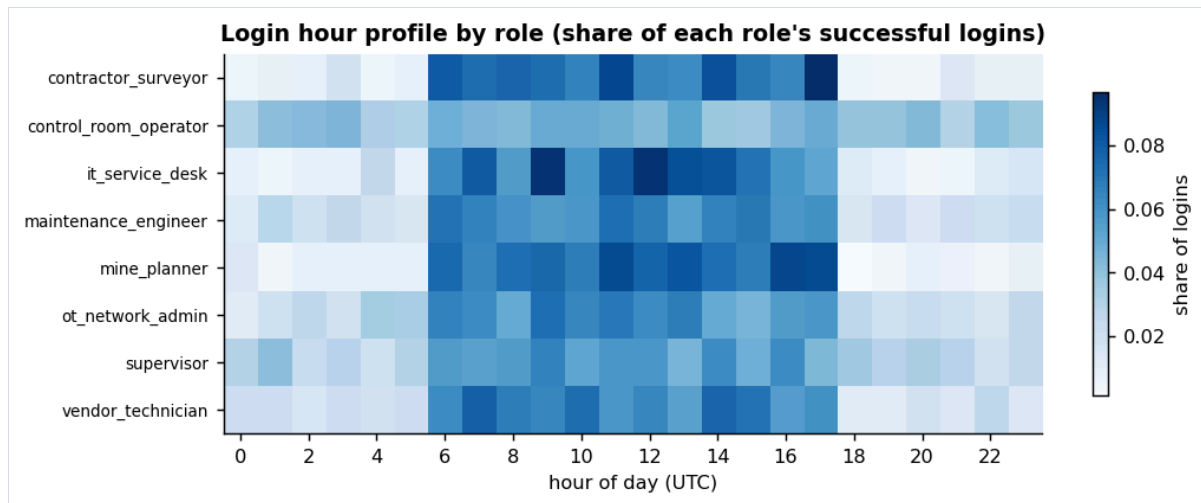


Figure 8. Login-hour baseline by role. Control-room operators and OT network administrators show genuine night activity, which is why an out-of-hours rule alone produces poor precision.

Four findings came out of this stage and were recorded in `outputs/tables/eda_findings.csv`:

area	finding	evidence
IIoT telemetry	Attack-labelled readings are not uniformly extreme	highest separation: weather/pressure with 26.4% of attack rows beyond 3 SD of the normal baseline; median across sensor-measures is 0.0%
Network flows	Connection state separates attack-labelled traffic strongly	state 'rej' carries 44,852 flows of which 100.0% are attack-labelled
Remote access	A small number of user-days break the behavioural baseline	45 of 2792 user-days (1.6%) show either ≥ 3 failed logins, more than one source country, or any non-domestic source address; the 99th percentile of daily failures is 2.0
Remote access	Baseline authentication failure rate	2.01% of all access events are failures (455 of 22,686)

Table 8. Exploratory findings with the evidence that supports each one.

5.1 Initial security hypotheses

#	Hypothesis	Evidence in the data	Status
H1	Remote access, not the sensors themselves, is the most exposed path into the OT zone	Access events carry privileged actions without MFA from external addresses; telemetry anomalies alone rarely exceed the normal envelope	Supported so far; drives the investigation in section 7 and the simulation in section 9
H2	Attack traffic is separable from normal traffic by connection behaviour rather than by volume	Connection state and protocol dominate feature importance; byte and duration features contribute little	Supported; also explains why the evasion test in section 11 has little effect
H3	Sensor readings alone are a weak detector of manipulation	Median share of attack-labelled readings beyond three standard deviations of the normal baseline is 0 per cent across sensor-measure pairs	Supported; argues for learned models over threshold alarms
H4	Unusual behaviour is concentrated in a small number of account-days	45 of 2,792 user-days (1.6 per cent) break the simple behavioural rules	Supported; sets the alerting budget used for the risk bands

Table 9. Working hypotheses carried into the modelling stages.

6. Supervised model and anomaly/behavioural model

6.1 Supervised intrusion detection

Three candidate models were compared on three-fold cross-validated F1 using the training split only; the test split was scored once, at the end. Exact duplicates were removed before splitting, which matters: 20,569 identical rows exist in the flow data and would otherwise appear on both sides of the split.

model	cv_f1_mean	cv_f1_sd
random_forest	0.9983	0.0001
decision_tree	0.9924	0.0006
logistic_regression	0.969	0.0015

Table 10. Model selection by cross-validated F1 on the training data.

model	accuracy	precision	recall	f1	roc_auc	pr_auc
logistic_regression	0.9556	0.9934	0.9493	0.9708	0.9944	0.9983
decision_tree	0.9923	0.9959	0.9942	0.9951	0.9959	0.9977
random_forest	0.998	0.9987	0.9987	0.9987	1.0	1.0

Table 11. Held-out performance on 30 per cent of the flow data.

The random forest was selected. The justification is not the margin in the table but the shape of the data: flow records mix skewed numeric measures with categorical protocol fields that interact, which is what a tree ensemble handles without scaling assumptions. Logistic regression is kept as a transparent baseline and shows that much of the problem is linearly separable, although it still misses 5.1 per cent of attacks against 0.1 per cent for the forest.

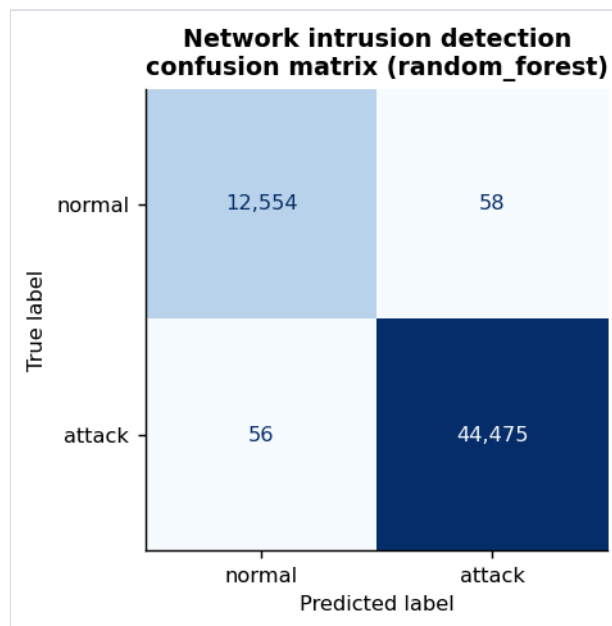


Figure 9. Confusion matrix for the selected network detector on the held-out split.

family	precision	recall	f1	support
backdoor	1.0	1.0	1.0	5613
ddos	0.988	0.982	0.985	5998
dos	0.994	0.982	0.988	5698
injection	0.982	0.968	0.975	5989

family	precision	recall	f1	support
mitm	0.662	0.846	0.743	312
normal	0.995	0.997	0.996	12612
password	0.996	0.989	0.992	5959
ransomware	0.999	1.0	0.999	4421
scanning	0.991	0.992	0.992	6000
xss	0.963	0.986	0.975	4541

Table 12. Attack-family identification (macro-F1 0.9645). The weakest class, mitm, has the fewest test examples.

model	accuracy	precision	recall	f1	roc_auc	pr_auc
logistic_regression	0.6244	0.5735	0.5917	0.5825	0.7852	0.723
random_forest	0.9901	0.9998	0.9779	0.9887	0.9985	0.9985

Table 13. Modbus telemetry classifier. The gap between the linear and the ensemble model is the evidence that OT protocol abuse is not linearly separable.

feature	importance	sd
proto	0.0608	0.0007
service	0.0008	0.0001
is_internal_dst	0.0007	0.0002
dst_port	0.0006	0.0002
src_ip_bytes	0.0005	0.0001
src_port	0.0004	0.0001

Table 14. Permutation importance for the network detector: mean F1 decrease when each feature is shuffled.

6.2 Anomaly and behavioural methods

Two framings were run on the network flows, and the contrast is the most useful methodological result in the project.

Negative result, reported deliberately. Fitted on all flows with no labels, an Isolation Forest scores ROC-AUC 0.28 — below chance. The cause is that 78% of this capture is attack traffic, so what is statistically rare is ordinary office traffic. Fitting the same model on known-good traffic only, and scoring novelty against it, raises ROC-AUC to 0.72. The operational lesson for a mine is that anomaly detection needs a trusted baseline window rather than “whatever is rare today”.

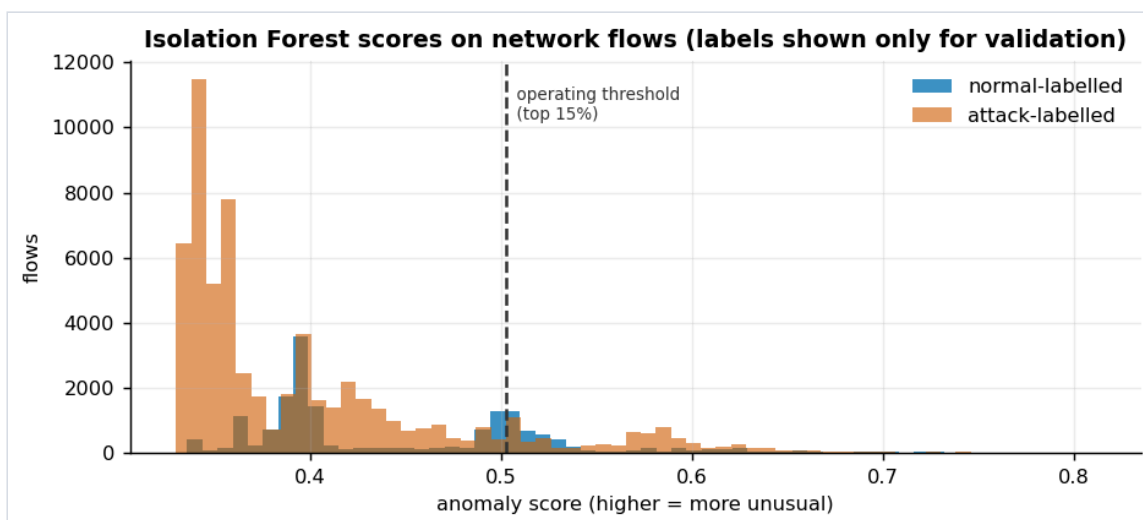


Figure 13. Isolation Forest score distribution on network flows. Labels are shown for validation only; they were not used for fitting.

On the remote-access data, where anomalies genuinely are rare, the same method performs well. The operating threshold is the 98th percentile of the score, which is an alerting budget decision rather than a statistical one: it produces about two cases per working day for an estate of 114 accounts.

method	flagged	precision_vs_injected	recall_vs_injected	f1	roc_auc_vs_injected
iso	56	0.643	0.818	0.72	0.997
lof	56	0.107	0.136	0.12	0.501

Table 15. Anomaly methods on user-day behaviour, validated against the injected patterns. Local Outlier Factor does not beat chance on these features.

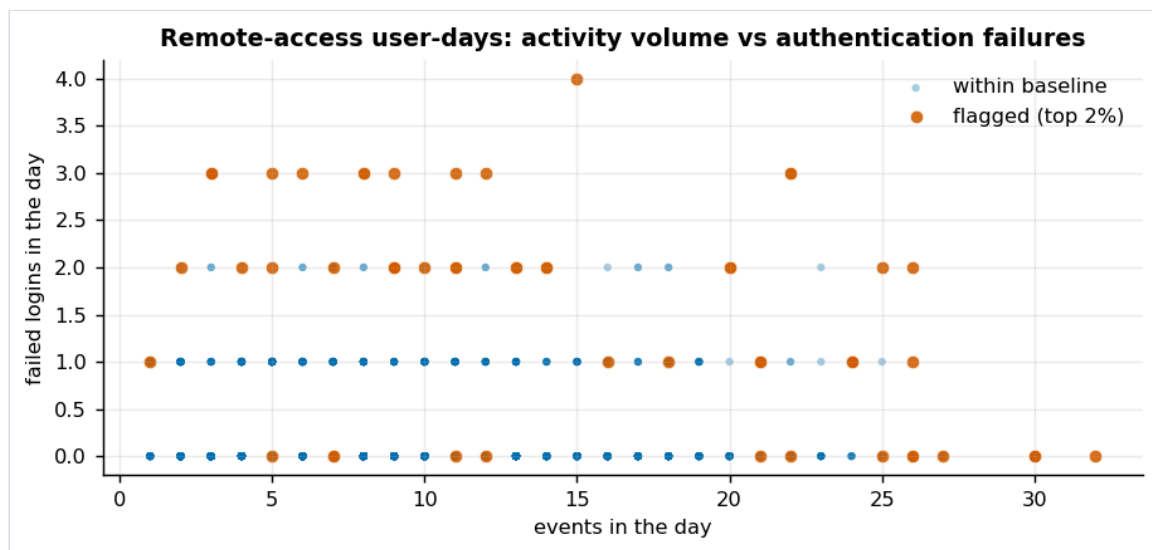


Figure 15. User-days by activity volume and failed logins, with the flagged 2 per cent highlighted.

username	role	day	failures	distinct_countries	out_of_hours	why_flagged
cont006	control_room_operator	2019-04-24	2	2	13	external +10.7 SD vs role mean; foreign +10.7 SD vs role mean; distinct_countries +9.2 SD vs role mean
vend069	vendor_technician	2019-04-25	1	2	8	distinct_countries +6.5 SD vs role mean; foreign +6.4 SD vs role mean; external +6.4 SD vs role mean
supe112	supervisor	2019-04-24	4	2	5	distinct_countries +11.6 SD vs role mean; foreign +11.3 SD vs role mean; external +11.3 SD vs role mean
main042	maintenance_engineer	2019-04-24	2	2	9	external +11.6 SD vs role mean; foreign +11.6 SD vs role mean; distinct_countries +7.5 SD vs role mean
cont015	control_room_operator	2019-04-24	3	2	8	external +10.7 SD vs role mean; foreign +10.7 SD vs role mean; distinct_countries +9.2 SD vs role mean

username	role	day	failures	distinct_countries	out_of_hours	why_flagged
cont080	contractor_surveyor	2019-04-24	3	2	7	distinct_countries +6.4 SD vs role mean; failures +5.8 SD vs role mean; foreign +5.4 SD vs role mean
cont021	control_room_operator	2019-04-24	3	2	9	external +10.7 SD vs role mean; foreign +10.7 SD vs role mean; distinct_countries +9.2 SD vs role mean
main049	maintenance_engineer	2019-04-24	3	2	3	external +11.6 SD vs role mean; foreign +11.6 SD vs role mean; distinct_countries +7.5 SD vs role mean

Table 16. Highest-scoring flagged user-days with the reason the model gives, expressed as deviations from the role baseline.

7. Incident timeline, access findings and response logic

7.1 Access and identity analytics

Seven behaviour rules were implemented on top of the measured baselines. Each alert records the rule, the account, the asset, the source address and the identifiers of the events that prove it, so an analyst never has to trust a score alone.

rule	severity	alerts	accounts	matched_injected	precision_vs_injected
R1	medium	11	11	11	1.0
R2	high	1	1	1	1.0
R3	high	3	3	3	1.0
R4	medium	101	30	6	0.06
R5	low	41	40	41	1.0
R6	high	1	1	1	1.0
R7	high	18	2	18	1.0

Table 17. Rule performance against the injected behaviour patterns. R4 is retained deliberately as the tuning counter-example.

Six of the seven rules match injected behaviour at full precision. Rule R4, which fires on privileged actions outside an account's usual hours, produced 101 alerts at 6% precision. That is not a failure to hide but the expected consequence of shift work in a mine: control-room operators and OT administrators legitimately work at night, as Figure 8 shows. The rule is kept, the weakness is logged as defect D07, and the planned fix is role-aware working windows.

7.2 Selected case

Cases were ranked by alert weight, rule diversity and peak anomaly score. The strongest case is account vend069, a vendor technician on a vendor contract, active on 4 consecutive nights. The account performed 16 privileged actions on OT targets, 16 of them without multi-factor authentication, from a foreign source address and outside any approved maintenance window.

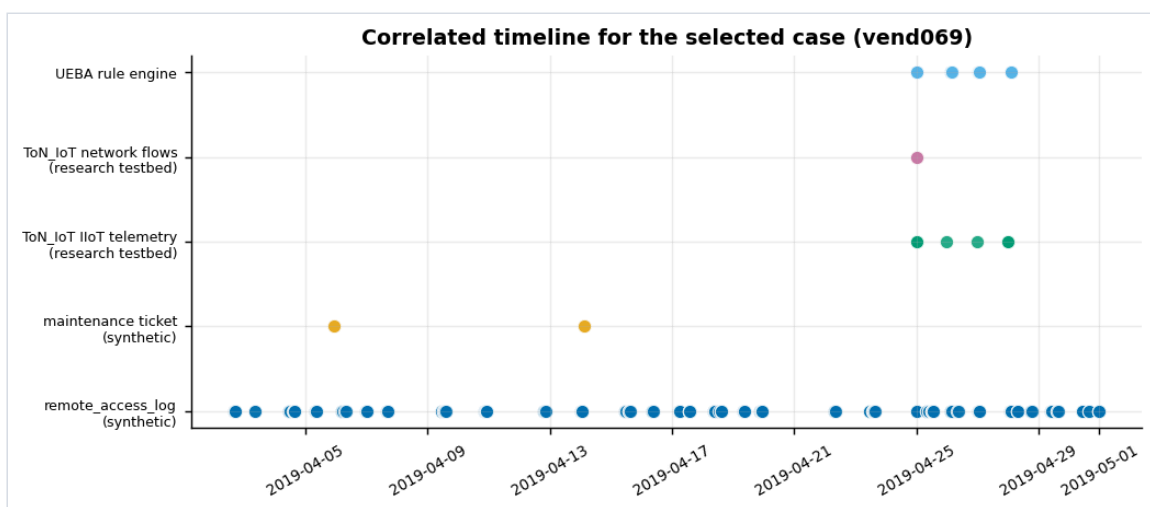


Figure 19. Correlated timeline for the selected case, by source.

How to read the timeline. Of 202 rows, 169 are direct evidence about the account and 11 are marked CONTEXT ONLY. Context rows come from the ToN_IoT captures, which are a different environment entirely; they share the calendar window by design and carry no shared identifiers. The linkage_basis column states this for every row. The case is an analytical scenario built on synthetic access data, not a real incident.

asset_id	asset_type	site	criticality	primary_protocol	patch_status
AST-0017	sensor_thermostat	PIT-A	medium	mqtt	behind_1_cycle
AST-0090	laptop	PLANT-01	medium	nan	behind_2_cycles
AST-0124	plc	WORKSHOP-01	critical	modbus	current
AST-0133	iiot_gateway	WORKSHOP-01	high	mqtt	behind_1_cycle
AST-0135	sensor_weather	WORKSHOP-01	medium	mqtt	behind_1_cycle
AST-0137	sensor_weather	WORKSHOP-01	medium	mqtt	current
AST-0142	sensor_motion	WORKSHOP-01	low	mqtt	current
AST-0152	laptop	WORKSHOP-01	medium	nan	behind_2_cycles

Table 18. Affected entities identified from the timeline (extract).

7.3 Response logic

The response plan is tied to what the evidence shows rather than to a generic checklist; each action carries the observation that justifies it.

phase	action	evidence_basis
Containment	Suspend the remote-access entitlement for vend069 and terminate active sessions	16 privileged actions in the window, 16 of them without MFA
Containment	Block the external source addresses at the VPN concentrator	non-domestic sources observed: 41.182.90.6 (ZAF)
Containment	Place the OT jump host and the engineering workstation used in the window under enhanced logging	out-of-hours privileged access to OT targets
Eradication	Reset credentials and re-enrol MFA for the account, and review any keys or tokens issued to it	authentication occurred without MFA
Eradication	Verify the configuration of the assets listed in incident_affected_entities.csv against a known-good export	8 assets touched in the window
Recovery	Restore vendor access only through a time-boxed, approved maintenance window with supervision	activity fell outside any approved window
Recovery	Confirm normal telemetry and control behaviour for the affected assets before closing the case	telemetry context rows in the same window
Monitoring	Keep rules R2, R3, R6 and R7 at high severity and review R4 tuning	R4 produced the majority of alerts at low precision against known behaviour
Monitoring	Alert on any first-seen country for privileged accounts (rule R5)	R5 matched every injected pattern in the test window

Table 19. Containment, eradication, recovery and monitoring actions with their evidence basis.

8. Security intelligence requirements, enrichment and first products

Five priority intelligence requirements were defined, each with the sources that answer it and a review cycle, so that analysis is driven by a question rather than by whatever the data happens to contain.

pir	question	sources	review_cycle
PIR1	Which remote accounts show behaviour consistent with credential abuse, and which assets did they touch?	access log, UEBA rules, anomaly model	daily
PIR2	Is there evidence of an attacker reaching the OT zone or an industrial protocol (Modbus, DNP3, MQTT)?	network flows, Modbus telemetry classifier	daily
PIR3	Which IIoT devices or network sources deviate from their established behavioural baseline?	telemetry baselines, Isolation Forest	daily
PIR4	Which control package most reduces the chance of an intrusion reaching critical OT assets?	Monte Carlo simulation	quarterly
PIR5	Are maintenance and incident reports describing security-relevant conditions that the technical telemetry has not surfaced?	ticket corpus, ATT&CK enrichment	weekly

Table 20. Priority intelligence requirements for the mining environment.

Enrichment links each detection rule to the closest descriptions in the MITRE ATT&CK for ICS corpus by TF-IDF similarity. The mapping is derived rather than asserted, and the similarity score and a confidence label are reported with it. Where the match is weak, the table says so instead of presenting a confident mapping.

rule	attack_id	attack_name	similarity	confidence
R1	DC0002	User Account Authentication	0.246	moderate
R2	M0927	Password Policies	0.363	moderate
R3	M0936	Account Use Policies	0.141	low - reported for context only
R4	AN1935	Analytic 1935	0.207	moderate
R5	M0936	Account Use Policies	0.244	moderate
R6	M0935	Limit Access to Resource Over Network	0.219	moderate
R7	DC0002	User Account Authentication	0.381	moderate

Table 21. Nearest ATT&CK for ICS entry for each detection rule, with the similarity score that produced it.

Two products are produced. The **operational** product is a prioritised watchlist of 115 accounts combining alert weight, peak risk score and account attributes such as privilege and MFA enrolment; the top ten accounts are linked to the 52 assets they touched, ordered by criticality. The **executive** product is a one-page brief stating the key risks, the affected assets, the modelled effect of each control and what the group is not claiming. Both are generated from the analytical outputs, so they cannot contradict the technical results.

username	user_role	employment_type	alerts	rules	highest_sev	max_risk	band
vend069	vendor_technician	vendor	22	R3,R4,R5,R7	high	98.1	critical
cont081	contractor_surveyor	contractor	8	R1,R4,R5,R6,R7	high	90.9	critical
main029	maintenance_engineer	employee	9	R4,R5	medium	75.6	moderate
supe112	supervisor	employee	6	R1,R4,R5	medium	96.0	critical
ot054	ot_network_admin	employee	8	R4,R5	medium	74.5	moderate
ot051	ot_network_admin	employee	5	R3,R4,R5	high	76.0	high
cont001	control_room_operator	employee	7	R4	medium	73.6	moderate
ot052	ot_network_admin	employee	6	R4	medium	76.9	high

Table 22. Operational watchlist (extract). Full table: [outputs/tables/intel_operational_watchlist.csv](#).

9. Simulation design and preliminary comparative results

The charter proposed a small segmentation simulation. This was extended to five control scenarios, because the access analysis showed that authentication, not only segmentation, is where this environment is exposed.

Model. The mine is represented as a directed graph built from the asset inventory: 195 nodes and 1963 edges spanning the internet, the IT zone, the IT-OT boundary and the OT zone. A run begins with one compromised remote-access session. At each step every compromised host attempts each outgoing link once, succeeding with a probability that depends on the boundary being crossed and on the controls in force. A run ends after 12 steps or when nothing new can be reached. 5,000 runs were executed per scenario, above the 1,000 the specification requires.

Inputs. One input is measured from our own data: the probability that a stolen remote credential yields a foothold is taken as the share of external privileged access events that had no MFA, which is 0.947 over 19 events. The per-boundary transmission probabilities and the effect size of each control are assumptions, stated in `outputs/tables/simulation_summary.json` and tested for sensitivity.

scenario	description	p_reach_ot	p_reach_critical	mean_assets_compromised	rel_reduction_ot
S0_baseline	current controls as described in the asset inventory	0.541	0.539	29.598	0.0
S1_segmentation	IT-OT to OT traffic restricted to approved flows	0.344	0.316	18.477	0.364
S2_strong_auth	MFA enforced for every remote and privileged session	0.19	0.189	10.118	0.648
S3_monitoring	detection and isolation of a compromised host after 2 steps	0.51	0.498	18.045	0.057
S4_combined	all three control packages together	0.1	0.082	3.004	0.814

Table 23. Comparative results across five control scenarios, 5,000 runs each. Confidence intervals are in the source file.

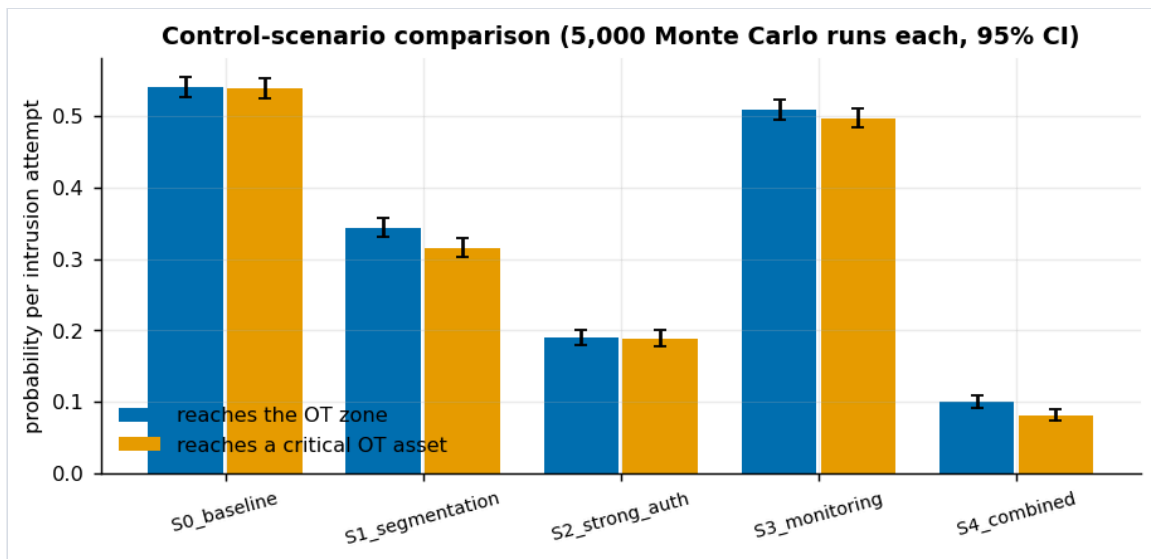


Figure 20. Probability of reaching the OT zone and a critical OT asset, with 95 per cent Wilson confidence intervals.

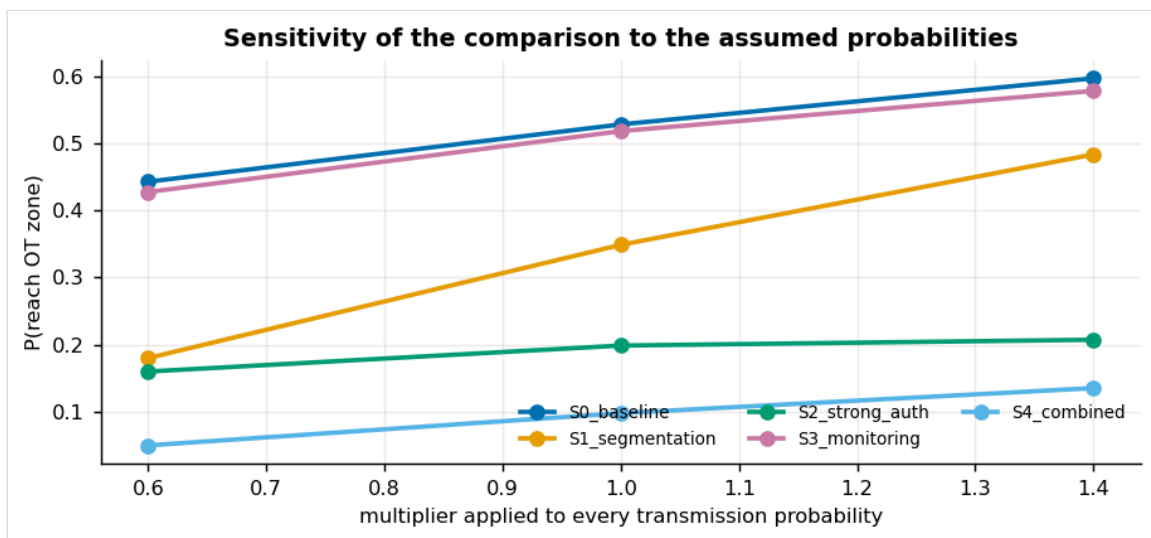


Figure 21. Sensitivity of the comparison when every transmission probability is scaled by 0.6, 1.0 and 1.4.

Under these assumptions, enforcing MFA on remote and privileged sessions is the single most effective control, reducing the chance of reaching the OT zone by 65%, followed by segmentation at 36%. Detection and isolation on its own has the smallest effect on reach (6%) but cuts the number of assets compromised from 30 to 18. The combined package reduces reach by 81%.

Two honest qualifications. First, MFA dominates partly because the measured foothold probability is high, and that figure comes from only 19 events in a synthetic log. Second, the absolute probabilities depend on assumed parameters; what is stable is the ranking, which holds across every point in the sensitivity sweep. The simulation therefore supports a comparison between control packages, not a forecast of how often a real intrusion would occur.

10. Text-mining and NLP workflow and preliminary outputs

The charter made this component conditional on suitable data being available. Two corpora were assembled, giving 677 unstructured records against the specification's minimum of 200: 320 synthetic maintenance and incident tickets with category labels, and 357 real MITRE ATT&CK for ICS descriptions.

Workflow. Text is lower-cased, punctuation that is not part of an indicator is stripped, and whitespace is collapsed. Features are TF-IDF over unigrams and bigrams with English stop words removed. Three tasks follow: classification of ticket category, indicator extraction, and topic structure with enrichment.

class	precision	recall	f1	support
access_request	1.0	1.0	1.0	17.0
instrumentation	1.0	1.0	1.0	20.0
mechanical	1.0	1.0	1.0	21.0
network_fault	1.0	1.0	1.0	19.0
security_incident	1.0	1.0	1.0	19.0
macro avg	1.0	1.0	1.0	96.0
weighted avg	1.0	1.0	1.0	96.0

Table 24. Ticket classification on a held-out 30 per cent.

Caveat that must be stated. The tickets are generated from a template bank, so each category has a highly consistent vocabulary and the task is far easier than real ticket text. The perfect score is evidence that the pipeline works end to end, not an estimate of accuracy on a real ticket system.

Indicator extraction uses regular expressions for IP addresses, asset identifiers, accounts, sites and protocols, plus a gazetteer of malware names taken from the ATT&CK corpus. Because the generator recorded which entities it placed in each ticket, the extractor can be scored rather than described: precision 0.972, recall 0.997, F1 0.984 (594 true positives, 17 false positives, 2 false negatives).

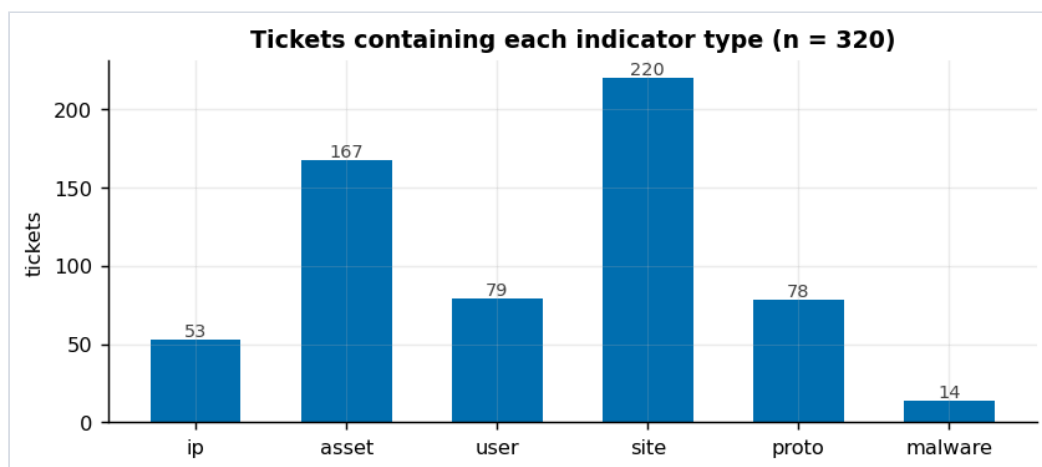


Figure 23. Tickets containing each indicator type.

Topic structure and enrichment. Six topics were extracted from the ATT&CK corpus with non-negative matrix factorisation, and every ticket was matched to its nearest ATT&CK description by TF-IDF similarity. 225 of 320 tickets matched at a similarity of 0.15 or above, which is the enrichment that feeds the intelligence products in section 8.

topic	top_terms
T1	attack, org, mitre org, attack mitre, https attack, https, mitre, org software, citation, software, org groups, groups
T2	standard detection, exists technique, method currently, currently exists, detection method, currently, exists, method, standard, detection, technique, easily
T3	adversaries, control, devices, adversary, systems, access, environment, citation, device, techniques, process, network
T4	communications, help, blocked, technique used, loss, technique, alarms, identify loss, help identify, loss communications, monitor, indicate
T5	program, management, alarms, monitor, monitor device, devices produce, produce, program download, download, logs, devices, device
T6	monitor, network, files, file, traffic, executed, windows, changes, data, user, arguments, suspicious

Table 25. Topics extracted from the ATT&CK for ICS corpus, described by their leading terms.

11. Predictive risk method and adversarial test cases

11.1 Daily risk score

Each account-day receives a score from 0 to 100 built from six components that an analyst can read, each normalised as a percentile rank and weighted: failed logins (0.15), activity outside the account's normal hours (0.10), external or foreign source addresses (0.20), privileged actions without MFA (0.20), the anomaly score (0.20) and data egress volume (0.15). The score records its own largest contributor, so the console can state why a day scored as it did.

Band cut-points are set from the score distribution rather than from round numbers, because with percentile components an average account already scores about 50. The bands are an alerting budget: roughly the top 0.5 per cent critical, 1.5 per cent high and 8 per cent moderate.

risk_band	user_days	share	injected_rows	mean_score
critical	15	0.005	12	89.5
high	42	0.015	17	78.85
moderate	223	0.08	15	69.99
low	2512	0.9	0	47.527

Table 26. Risk bands, the volume of work each implies, and how many injected behaviour rows each band caught.

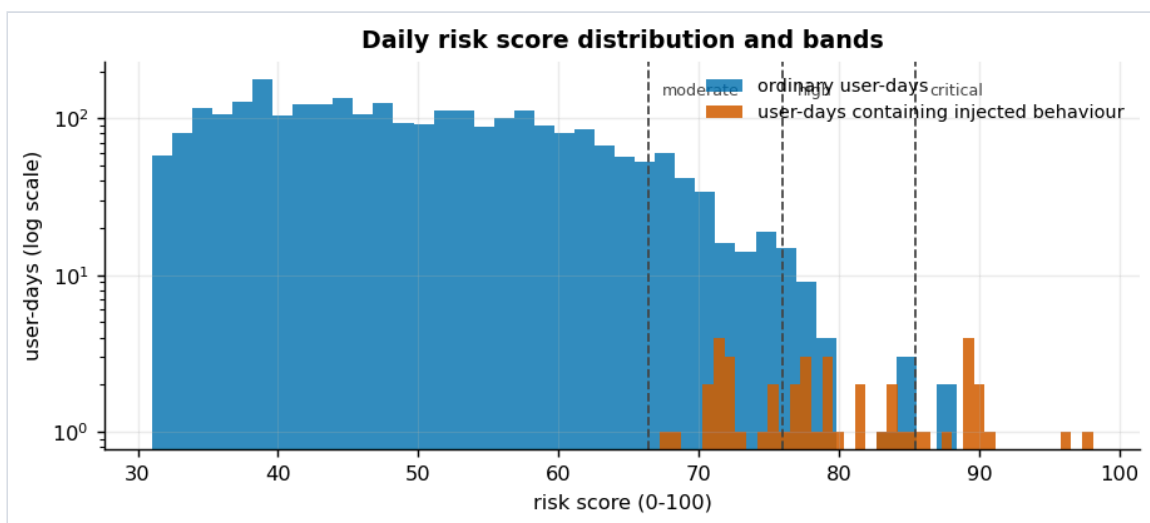


Figure 24. Risk score distribution with band cut-points. The vertical scale is logarithmic.

Validation: the score separates user-days containing injected behaviour with ROC-AUC 0.988, and 75% of the twenty highest-scoring user-days contain injected behaviour.

11.2 Early warning

A logistic regression was trained on the earlier 70 per cent of days to predict whether an account would raise an alert on the following day, and tested on the later days. The result is weak: ROC-AUC 0.528 against a base rate of 0.082. This is reported as a negative result rather than tuned until it looked better. Alerts in this data are driven by single events rather than by a build-up in the previous day's behaviour, so there is little for a next-day model to learn. A longer observation window or event-level features would be the next thing to try.

11.3 Adversarial and robustness tests

Four families of test were run against the deployed network detector, each at three severities, on the held-out split only.

test	setting	f1	recall_on_attacks	f1_change_vs_baseline
T0_baseline	unmodified held-out flows	0.9987	0.9988	0.0
T1_drift_noise	multiplicative Gaussian noise, sigma=0.05	0.9983	0.9982	-0.0004
T1_drift_noise	multiplicative Gaussian noise, sigma=0.15	0.9953	0.9963	-0.0033
T1_drift_noise	multiplicative Gaussian noise, sigma=0.3	0.9877	0.9873	-0.011
T2_evasion	attack flows padded x1.5 and slowed x2.0, conn_state=sf	0.9986	0.9986	-0.0001
T2_evasion	attack flows padded x3.0 and slowed x5.0, conn_state=sf	0.9982	0.9978	-0.0005
T2_evasion	attack flows padded x6.0 and slowed x10.0, conn_state=sf	0.9977	0.9968	-0.001
T3_missing_data	10% of feature values lost	0.9906	0.9854	-0.0081
T3_missing_data	25% of feature values lost	0.9499	0.9169	-0.0488
T3_missing_data	50% of feature values lost	0.7728	0.6449	-0.2258
T4_label_poisoning	5% of training labels flipped	0.9979	0.9985	-0.0008
T4_label_poisoning	15% of training labels flipped	0.9944	0.9932	-0.0042
T4_label_poisoning	30% of training labels flipped	0.9582	0.9357	-0.0405

Table 27. Detector performance under drift, evasion, missing data and label poisoning.

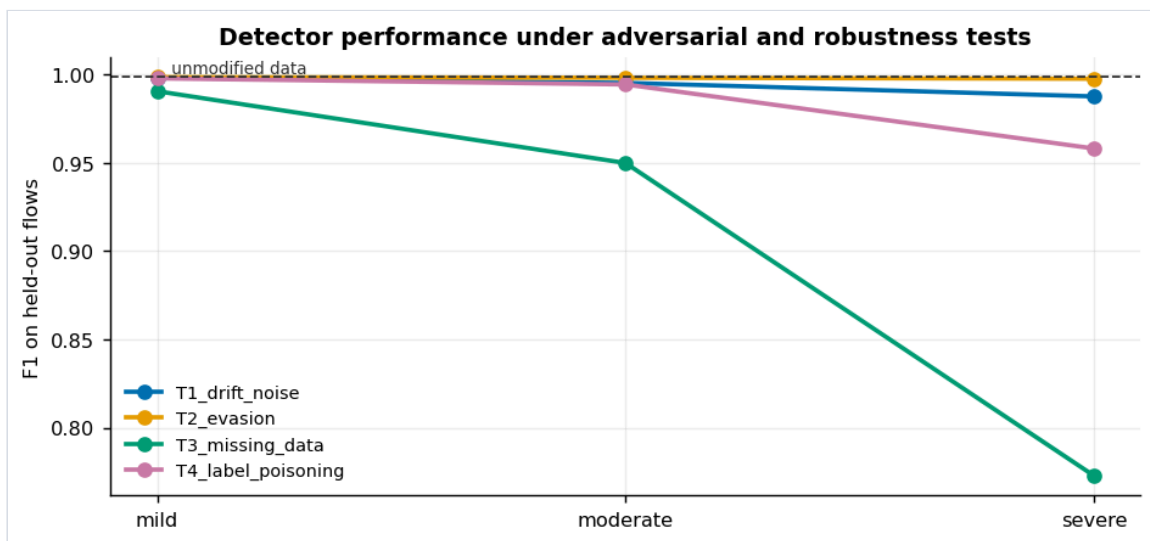


Figure 25. F1 under increasing severity for each test family, against the unmodified baseline.

Three conclusions follow. Collection reliability is the largest risk: losing half the collected fields costs 0.23 of F1, which makes telemetry completeness a security control in its own right. Label poisoning has to reach roughly a third of the training set before it does comparable damage, which argues for controlling who may label data. The evasion test is the weakest of the four, because it perturbs volume features while the detector relies on protocol fields; a stronger test that perturbs those fields is recorded as backlog item B02 rather than claimed as a result.

12. Working prototype, test cases, known defects and backlog

12.1 Prototype

The analyst console is a Streamlit application with eight views, launched with `streamlit run app/app.py`. It is organised the way an analyst works rather than by algorithm: *Overview* (volumes, alerts per day, risk bands), *Accounts & risk* (prioritised watchlist, per-account drill-down showing the risk components and the raw events), *Anomalies*, *Investigation* (timeline, affected entities, response plan), *Intelligence* (requirements, ATT&CK mapping, executive brief), *Simulation*, *Models & robustness*, and *Data & method* (inventory, cleaning log, dictionary, compliance checklist).

The decision the console supports is triage: which account or asset to work next, on what evidence, and what to do about it. Every view ends in something actionable rather than in a chart. A reproducible notebook, `notebooks/capstone_walkthrough.ipynb`, accompanies it and reproduces every number quoted in this document.

The screenshots below were captured from the running application, not mocked up. They are reproduced by `python src/s19_app_screenshots.py`, which starts the console and drives it in a headless browser.

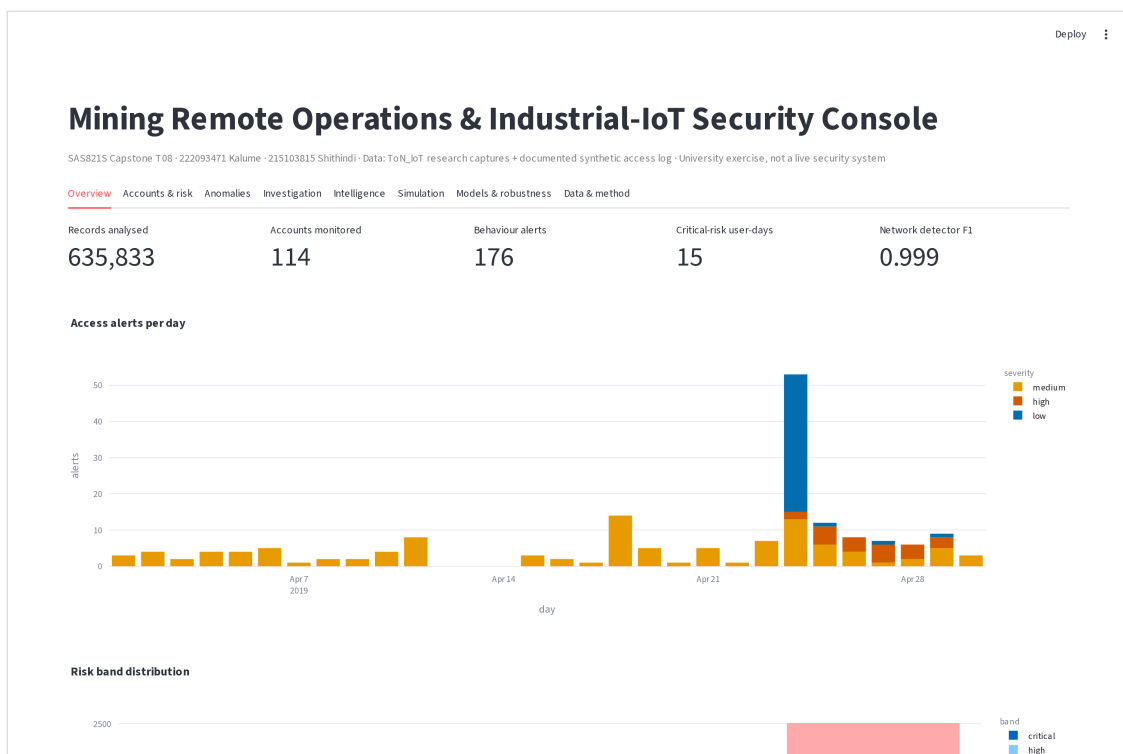


Figure 27. Console, Overview: volume of records analysed, accounts monitored, alerts raised, critical-risk user-days and the detector's F1, with alerts per day by severity.

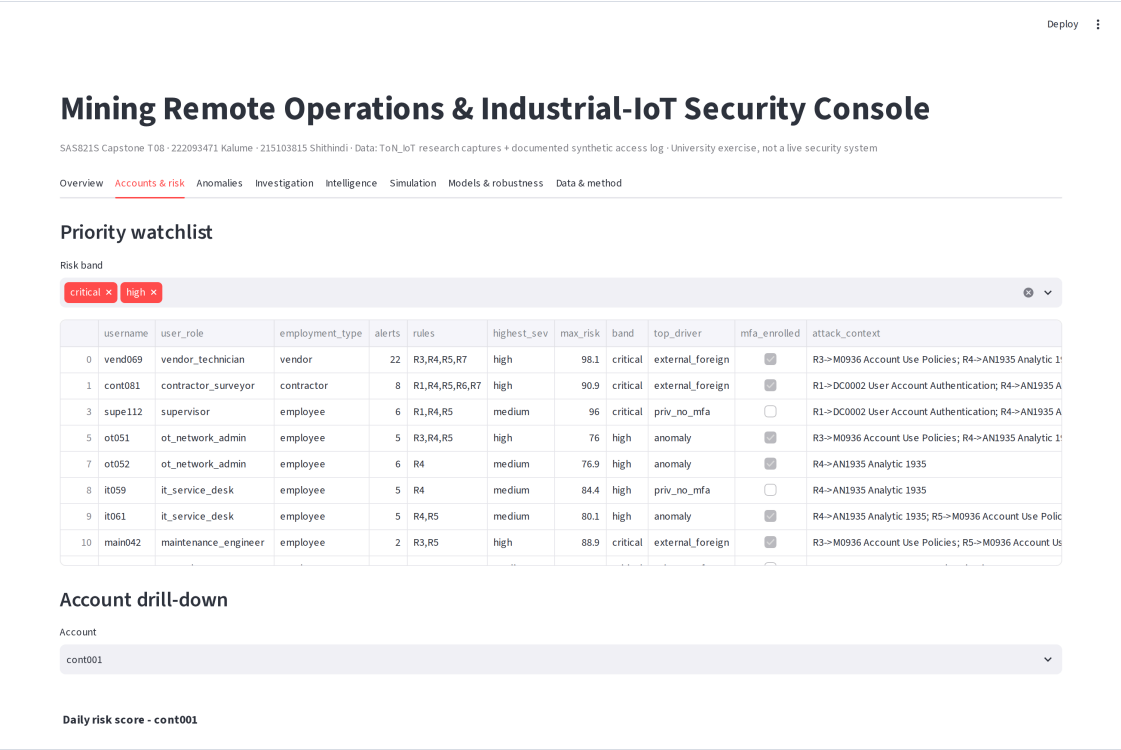


Figure 28. Console, Accounts and risk: the priority watchlist filtered to the critical and high bands, showing which rules fired, the peak risk score, the dominant risk driver, MFA enrolment and the ATT&CK context for each account.

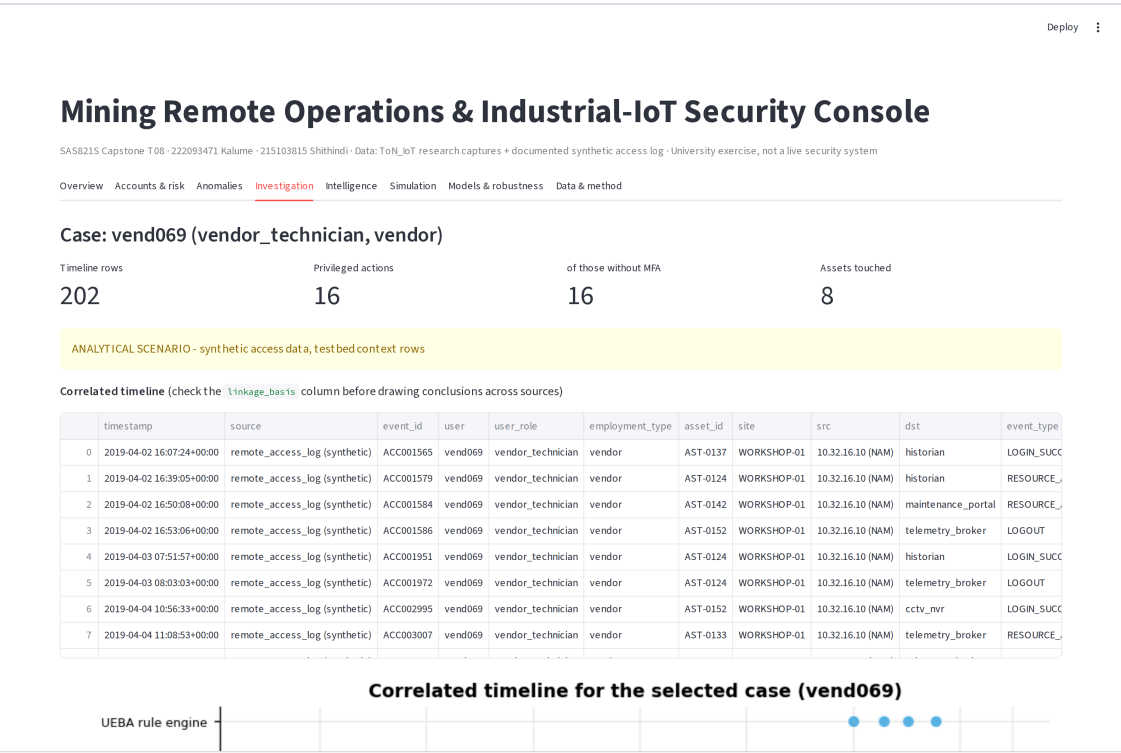


Figure 29. Console, Investigation: the selected case with its privileged-action counts, the correlated timeline including the linkage-basis column, the affected entities and the response plan.

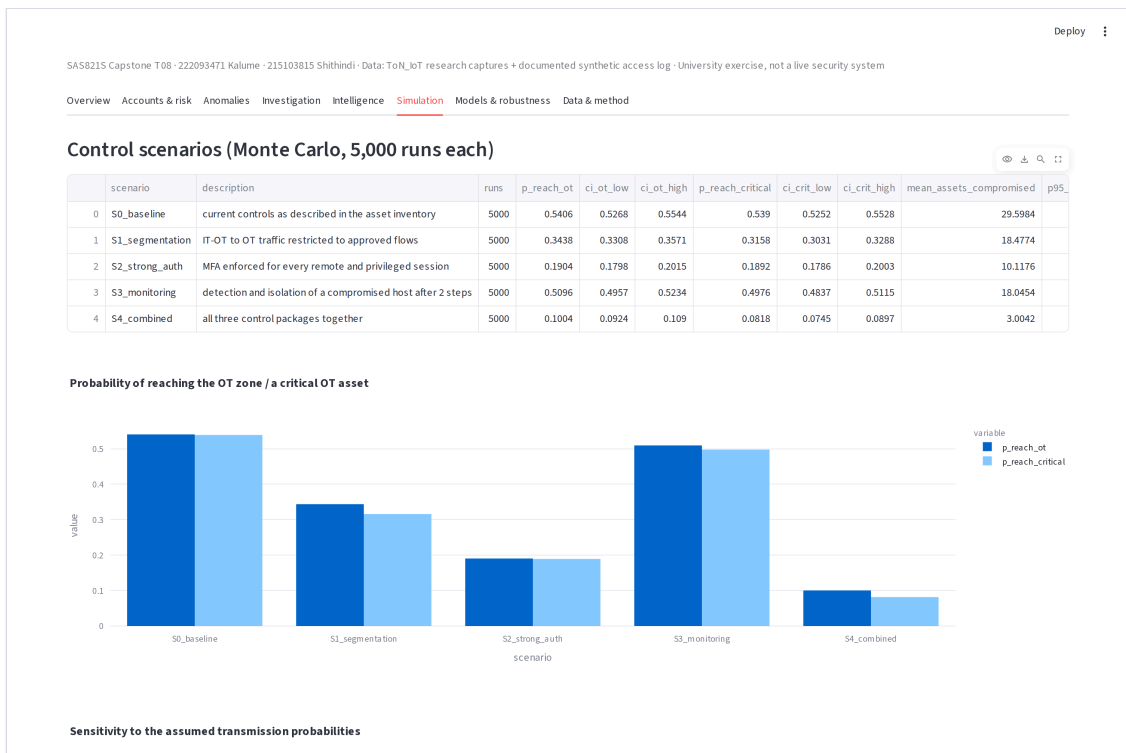


Figure 30. Console, Simulation: the control-scenario comparison and the sensitivity view, with the assumptions and limitations shown alongside the numbers.

12.2 Test cases

Sixteen test cases run with `python -m pytest tests -q` and all pass. They were written to catch the mistakes that actually occurred during development, not as decoration:

- raw sources carry provenance hashes, and the minimum-data requirements are met;
- the identity/access and network sources both exist, as C2 requires;
- duplicates are removed before the train/test split, and the count matches the data;
- Zeek placeholders do not survive into the processed data;
- country codes are not parsed as missing values (a regression test for defect D02);
- timestamps are timezone-aware and inside the generation window;
- every alert cites evidence identifiers, and every timeline row states its linkage basis;
- the simulation has at least three scenarios and at least 1,000 runs each;
- risk scores stay within bounds and the bands are correctly ordered;
- no adversarial perturbation improves the score, and at least three families are covered;
- every evidence file named in the compliance checklist exists on disk.

12.3 Known defects and limitations

id	type	area	description	severity	status
D01	defect	data	The ToN_IoT flow mirror used here has no timestamp column, so network flows cannot be joined to other sources on time	medium	OPEN
D02	defect	data	Namibia's ISO-2 country code 'NA' was read by pandas as a missing value, making every user-day look foreign	high	FIXED
D03	defect	modelling	Isolation Forest fitted on all flows scores below chance (ROC-AUC 0.28) because attacks are the majority class in ToN_IoT	medium	FIXED BY DESIGN
D04	defect	modelling	The first adversarial baseline was computed on rows the model had trained on, inflating the reference F1	medium	FIXED
D05	limitation	data	Access log, tickets, asset inventory and user directory are synthetic	high	ACCEPTED

id	type	area	description	severity	status
D06	limitation	modelling	Ticket classification reaches macro-F1 1.000 because the corpus is template-generated	medium	ACCEPTED
D07	limitation	modelling	UEBA rule R4 (out-of-hours privileged action) fires 99 times at 4 per cent precision	low	OPEN
D08	limitation	modelling	Next-day early warning is weak (ROC-AUC 0.53) because alerts are rare and largely driven by single events	low	OPEN
D09	limitation	simulation	Transmission probabilities are assumed; only p_foothold is measured from the data	medium	ACCEPTED
D10	limitation	simulation	p_foothold of 0.947 comes from only 19 external privileged events in the synthetic log	medium	OPEN
D11	limitation	prototype	The Streamlit console reads pre-computed outputs rather than live data	low	OPEN
D12	limitation	scope	ToN_IoT is a research testbed, not mining equipment	high	ACCEPTED

Table 28. Known defects and limitations. Full workarounds are in docs/known_defects_and_backlog.csv.

12.4 Implementation backlog

id	area	description	workaround_or_plan
B01	data	Replace the synthetic access log with an approved authentic identity source if one is released	re-run stages 06-15; no code changes needed
B02	modelling	Evasion tests that perturb proto/service/conn_state, which the detector actually relies on	extend s15 test T2
B03	modelling	Per-device telemetry baselines instead of per-sensor-type baselines	requires a device identifier that ToN_IoT does not publish
B04	prototype	Analyst feedback capture in the console (true positive / false positive) to close the intelligence loop	small Streamlit form writing to a CSV
B05	process	Automated re-labelling and drift monitoring on a schedule	needed for C1 feedback stage to be fully automated

Table 29. Backlog carried into Milestone 3.

13. Repository, environment and contribution evidence

Repository. The project is a git repository with the structure `src/` (pipeline stages), `app/` (console), `notebooks/`, `data/raw` and `data/processed`, `outputs/` (tables, figures, models, logs), `docs/` and `tests/`. The two ToN_IoT datasets are not redistributed; the README gives the exact clone commands and the original UNSW source, and the ATT&CK bundle records the upstream commit hash.

Environment. `requirements.txt` pins the ten libraries used, and every summary file records the Python version, library versions and the random seed (3815, derived from a member's student number). `python src/run_all.py` reproduces every output from the raw sources in 1 seconds; `outputs/tables/experiment_log.json` records the runtime of each stage and `outputs/logs/run_log.txt` keeps an append-only log of every run.

stage	description	seconds
s16	architecture diagram	0.9
s17	Member A evidence pack (dictionary, evaluation, experiment log)	0.1
nb	build the walkthrough notebook	0.0
s20	compliance checklist C1-C10	0.0

Table 30. Stage runtimes from the last full pipeline run.

Contribution evidence. Module ownership and the review pairing are recorded in `docs/contribution_and_review.md`, which follows the RACI allocation in the charter: Member A owns data acquisition, cleaning, features, supervised and unsupervised modelling, the risk model and reproducibility; Member B owns the log-source architecture, access analytics, investigation, simulation, text mining and the intelligence products; both own the prototype, documentation and testing.

Declared honestly. The implementation was completed in a compressed working period with AI assistance, disclosed in full in `docs/ai_assistance_disclosure.md` as the charter's section 12 requires, and one member was unwell during that period. The commit history at the time of submission therefore does not yet show balanced authorship. Each member will commit the modules they own from their own account before Milestone 3, and the review notes will be recorded as issues. Both members remain responsible for explaining every component at the oral verification, and the Member A evidence pack (`docs/member_a_model_evaluation.md`, `docs/member_a_data_dictionary.md`, `docs/experiment_log.csv`) exists to support that.

14. Updated risk register and deviations from the charter

Risk (charter)	Likelihood	Impact	Mitigation (charter)	Status at Milestone 2
Data unavailable or unsuitable	High	High	Assess datasets early, prioritise public or synthetic alternatives	Closed. Public ToN_IoT captures obtained; identity and text sources generated under documented rules.
Privacy or sensitive data exposure	Low	High	Only authorised, public or synthetic data; anonymise identifiers; exclude credentials	Closed. No real personal data, credentials or live systems were used at any point.
Model bias or misleading results	Medium	High	Establish baselines, validate results, compare against known anomalies, document limitations	Managed. Leakage control, cross-validation, validation against known injected behaviour, and negative results reported rather than removed.
Scope or time overrun	High	High	Keep anomaly detection and user behaviour analytics as the core, make advanced methods conditional	Realised in part. The schedule compressed severely; all components were nonetheless implemented, with the weaker ones flagged instead of overstated.
Technical integration failure	Medium	Medium	Develop components independently before integrating, maintain version-controlled backups	Closed. Stages are independent modules writing to files; the console reads outputs only, and the full pipeline reruns cleanly.
Unequal contribution	Medium	Medium	Assign clear responsibilities, maintain contribution records, review progress	Open. One member was unwell during the implementation period; see section 13 and the contribution record.

Table 31. Charter risk register updated with current status.

14.1 Declared deviations

Change	Charter position	Milestone 2 position	Reason
Datasets named	Volumes and sources were to be determined after selection	ToN_IoT telemetry and flows; generated access log, tickets, asset and user context; ATT&CK for ICS corpus	Charter section 6 permits public, synthetic or approved data with documented provenance
Supervised ML specified	TBC	Logistic regression, decision tree and random forest; binary and multiclass	Required by C4; the labelled ToN_IoT data made it possible
Text mining implemented	Conditional on suitable data	320 labelled tickets plus 357 ATT&CK descriptions	Required by C8; a real public corpus removed the dependency on unavailable ticket data
Simulation widened	Segmentation scenarios only	Five scenarios: baseline, segmentation, MFA, monitoring, combined	The access analysis showed authentication was the dominant exposure, so testing it was necessary
Repository location	TBC	Local git repository, to be pushed to the group remote	Required for contribution evidence
Schedule	Ten-week plan, tasks 1 to 8	Implementation completed in a compressed period before the deadline	Stated plainly rather than presented as the original plan having run to schedule

Table 32. Differences between the approved charter and what was implemented, with the reason for each.

15. Implementation plan to Milestones 3 and 4

The table below is the live plan. Tasks T01 to T17 are complete and their evidence is in the repository; the remaining tasks carry to Milestone 3 (documentation, due 25 September 2026) and Milestone 4 (presentation and oral verification, 25–30 September 2026).

task_id	task	responsible	expected_output	status	estimated_completion
T01	Acquire and verify data sources	Member A	data/raw/ populated, SHA-256 in data_inventory.csv	DONE	19 Sep 2026
T02	Generate documented synthetic sources	Member B	3 synthetic CSVs + provenance JSONs	DONE	19 Sep 2026
T03	Data inventory and dictionary	Member A	data_inventory.csv, data_dictionary.csv, data_quality.csv	DONE	19 Sep 2026
T04	Requirements matrix	Member B	requirements_matrix.csv, minimum_data_check.csv	DONE	19 Sep 2026
T05	Cleaning and feature pipeline	Member A	processed parquet tables + cleaning_log.csv (37 actions)	DONE	19 Sep 2026
T06	Baselines and exploratory analytics	Member A	8 figures + baseline_*.csv + eda_findings.csv	DONE	19 Sep 2026
T07	Supervised detection	Member A	supervised_*.csv, confusion matrices, saved models	DONE	19 Sep 2026
T08	Anomaly detection	Member A	anomaly_*.csv, threshold tables, flagged user-days	DONE	19 Sep 2026
T09	Access analytics	Member B	ueba_alerts.csv, ueba_rule_summary.csv	DONE	19 Sep 2026
T10	Investigation and response	Member B	incident_*.csv + fig19	DONE	19 Sep 2026
T11	Control simulation	Member B	simulation_summary.csv, simulation_sensitivity.csv	DONE	19 Sep 2026
T12	Text mining and NLP	Member B	nlp_*.csv + fig22 fig23	DONE	19 Sep 2026
T13	Predictive risk and adversarial tests	Member A	risk_*.csv, adversarial_results.csv, fig24 fig25	DONE	19 Sep 2026
T14	Intelligence products	Member B	intel_*.csv, intelligence_executive_brief.md	DONE	19 Sep 2026
T15	Analyst prototype	Both	working dashboard verified in a headless browser	DONE	19 Sep 2026
T16	Reproducibility pack	Member A	green test run, reproducible pipeline	DONE	19 Sep 2026
T17	Compliance checklist	Member B	compliance_checklist.csv and .md	DONE	19 Sep 2026
T18	Repository and contribution evidence	Both	commit history showing both members	IN PROGRESS	20 Sep 2026
T19	Milestone 2 document	Both	submission PDF	TO DO	20 Sep 2026
T20	Presentation preparation	Both	deck + speaker notes	TO DO	25 Sep 2026

task_id	task	responsible	expected_output	status	estimated_completion
T21	Replace synthetic access log with an approved real source	Member B	updated results and caveats	BACKLOG	after Milestone 2
T22	Stronger evasion testing	Member A	extended adversarial_results.csv	BACKLOG	after Milestone 2
T23	Live ingestion for the prototype	Both	dashboard that updates on a schedule	BACKLOG	after Milestone 2

Table 33. Implementation plan with ownership, status and dependencies. Full detail in docs/implementation_plan.csv.

15.1 Priorities for Milestone 3

1. Split the repository commits so that both members' contributions are visible, and record the review notes as issues.
2. Strengthen the evasion test to perturb the categorical protocol features the detector actually relies on (backlog B02).
3. Make rule R4 role-aware so that shift patterns stop generating avoidable alerts (defect D07).
4. Add analyst feedback capture to the console, which closes the intelligence cycle's feedback stage that is currently documented but not automated (backlog B04).
5. Rehearse the presentation against the speaker notes, with both members able to answer on any component.

16. Limitations, ethics and AI assistance

Limitations. Four should be read alongside every result in this document.

1. ToN_IoT is a controlled laboratory testbed, not mining equipment. Scores close to 1.0 reflect a clean capture; the same models would need recalibration against site data before any operational use.
2. Attack traffic is the majority class in that capture, which is unlike any real network and directly explains the unsupervised anomaly result in section 6.
3. The identity/access source and the ticket corpus are synthetic, so detection results demonstrate that the methods find behaviour whose ground truth we know, not that an attacker was found.
4. The simulation's transmission probabilities are assumptions; only the foothold probability is measured, and from a small number of events.

Ethics. No real credentials, personal data, confidential information or live systems were involved. No testing was performed against any third-party infrastructure. The synthetic accounts are fictional and carry no connection to real people. Outputs that name accounts are marked need-to-know in the intelligence products.

AI assistance. Declared in full in docs/ai_assistance_disclosure.md, as the charter commits the group to do. AI assistance was used to build the pipeline, the console and the generated documentation. It supplied no data and produced no results: every figure in this document comes from running the code, the pipeline reruns end to end in 1 seconds, and the test suite and provenance hashes allow any claim here to be checked independently.

Appendix A. Requirement coverage C1-C10

Status is produced by a script that checks each evidence file exists when it runs, not by assertion.

code	requirement	evidence_produced	status	files_present	remaining_work
C1	Security analytics lifecycle	all 5 sources	COMPLETE	5/5	Feedback loop is documented but not yet automated (no re-labelling workflow).
C2	Multi-source data (>=3, incl. identity/access and network/OT)	5 source families, 635k+ records	COMPLETE	4/4	Access log and tickets are synthetic; this must be stated in the report and defence.
C3	Data engineering and baseline	dictionary + 37 cleaning actions + baselines	COMPLETE	5/5	Network flow source has no timestamp column, so time-based joins to it are not possible.
C4	Machine learning (supervised + unsupervised)	3 supervised models, IF/LOF/DBSCAN	COMPLETE	4/4	Scores on ToN_IoT are high because the capture is a controlled testbed.
C5	Security investigation	202-row timeline with evidence IDs	COMPLETE	3/3	The case is an analytical scenario built on synthetic access data, clearly labelled.
C6	Security intelligence	5 PIRs, ATT&CK mapping, 2 products	COMPLETE	4/4	ATT&CK mapping is TF-IDF similarity, not an analyst-validated mapping.
C7	Simulation of >=3 control scenarios	5 scenarios x 5,000 runs + sensitivity	COMPLETE	3/3	Transmission probabilities are assumed; only p_foathold is measured from data.
C8	Text mining / NLP	677 text records, classify + extract + topics	COMPLETE	4/4	Ticket text is template-generated, so classification accuracy is optimistic.
C9	Predictive risk + >=3 adversarial tests	risk score + 4 test families	COMPLETE	4/4	Next-day forecast is weak (ROC-AUC ~0.53); reported as a negative result.
C10	Decision-support prototype	Streamlit console (8 views) + notebook	COMPLETE	3/3	Prototype reads pre-computed outputs; it does not yet ingest live data.

Table 34. Compliance checklist against the standard technical specification.

Appendix B. Experiment log

id	area	experiment	result	decision
E01	data	Search for an accessible ToN_IoT mirror	Located public GitHub mirrors for the IoT telemetry and the Zeek flows	Cloned both; documented the clone commands in the README
E02	data	Check whether the flow mirror carries timestamps	No `ts` column in this mirror	Recorded as defect D01; cross-source joins use address and asset instead of time
E03	data	Choose an identity/access source for C2	Wrote a documented synthetic generator with a fixed seed	Accepted, with the synthetic status stated in every product
E04	data	Country codes in the access log	pandas read 'NA' as missing, so every user-day looked foreign (100% flagged)	Switched to ISO-3 codes and added a regression test (defect D02)

id	area	experiment	result	decision
E05	features	Handle Zeek '-' placeholders	Left as text the placeholder becomes an artificial predictor	Converted to missing; sparse columns excluded from features
E06	supervised	Compare LR, decision tree and random forest	RF 0.9983, DT 0.9924, LR 0.9690	Random Forest selected; the other two kept as interpretable comparators
E07	supervised	Duplicate leakage check	Removing them before the split changes the evaluation honestly	Duplicates flagged in the data and excluded from train and test
E08	supervised	Modbus telemetry classifier	RF F1 0.9887 against LR 0.5825	Kept both to show that the OT signal is non-linear
E09	anomaly	Isolation Forest on flows, fully unsupervised	ROC-AUC 0.279 - below chance because attacks are the majority class	Kept and reported as a finding rather than discarded
E10	anomaly	Isolation Forest fitted on known-good traffic only	ROC-AUC 0.716 on held-out flows	Adopted as the realistic framing for an OT site
E11	anomaly	LOF as a contrasting method on user-days	ROC-AUC 0.501 versus 0.997 for IF	IF retained for the prototype; LOF reported as a negative comparison
E12	access	Threshold for the failed-login burst rule	A threshold of 5 per hour produced no alerts at all	Lowered to 3 per hour, justified against the measured baseline
E13	access	Out-of-hours privileged action rule (R4)	99 alerts at 4% precision against injected behaviour	Kept deliberately as the tuning counter-example; flagged as defect D07
E14	simulation	First network graph was too densely connected	Every scenario compromised about 177 of 195 assets, so controls looked useless	Sparsened the OT and IT meshes, lowered base probabilities, shortened the horizon
E15	simulation	MFA modelled on internal edges	No effect, because the foothold node is already compromised at step 0	Moved the MFA effect onto the foothold probability, which is where it acts
E16	simulation	Final scenario comparison	P(reach OT): baseline 0.541 to combined 0.100	Ranking stable across all sensitivity scales
E17	nlp	Ticket classification	macro-F1 1.000 - optimistic because the corpus is template-generated	Kept, with the caveat recorded in the outputs and repeated in the report
E18	nlp	Indicator extraction scored against an answer key	precision 0.972, recall 0.997	Accepted; false positives come from extra entities not in the answer key
E19	risk	Risk band cut-points	Fixed cut-points put 44% of user-days in the 'high' band	Cut-points moved to score quantiles (0.900, 0.980, 0.995) as an alert budget
E20	risk	Next-day early warning	ROC-AUC 0.528 against a base rate of 0.082	Reported as a negative result rather than tuned until it looked better
E21	adversarial	First robustness baseline was computed on training rows	Reference F1 was inflated relative to the true held-out score	Stage-08 split reproduced exactly; only test rows are perturbed (defect D04)
E22	adversarial	Four perturbation families	Largest loss is missing data at 50% (F1 -0.23); evasion costs almost nothing	Evasion test recorded as insufficient; backlog item B02
E23	pipeline	End-to-end reproducibility run	Completed in 135 seconds; 16 test cases pass	Accepted as the Milestone 2 baseline

Table 35. Experiment log: what was tried, what happened and what was decided, including the failures.

Appendix C. Figure and file index

figure	file
fig01_telemetry_volume_over_time.png	outputs/figures/fig01_telemetry_volume_over_time.png
fig02_attack_mix_by_sensor.png	outputs/figures/fig02_attack_mix_by_sensor.png
fig03_modbus_registers.png	outputs/figures/fig03_modbus_registers.png
fig04_network_type_counts.png	outputs/figures/fig04_network_type_counts.png
fig05_network_service.png	outputs/figures/fig05_network_service.png
fig06_top_talkers.png	outputs/figures/fig06_top_talkers.png
fig07_access_events_over_time.png	outputs/figures/fig07_access_events_over_time.png
fig08_login_hour_by_role.png	outputs/figures/fig08_login_hour_by_role.png
fig09_confusion_network.png	outputs/figures/fig09_confusion_network.png
fig10_feature_importance_network.png	outputs/figures/fig10_feature_importance_network.png
fig11_confusion_network_multiclass.png	outputs/figures/fig11_confusion_network_multiclass.png
fig12_confusion_modbus.png	outputs/figures/fig12_confusion_modbus.png
fig13_network_anomaly_scores.png	outputs/figures/fig13_network_anomaly_scores.png
fig14_anomaly_share_by_type.png	outputs/figures/fig14_anomaly_share_by_type.png
fig15_access_anomaly_scatter.png	outputs/figures/fig15_access_anomaly_scatter.png
fig16_top_anomalous_user_days.png	outputs/figures/fig16_top_anomalous_user_days.png
fig17_ueba_rule_alerts.png	outputs/figures/fig17_ueba_rule_alerts.png
fig18_alerts_per_day.png	outputs/figures/fig18_alerts_per_day.png
fig19_incident_timeline.png	outputs/figures/fig19_incident_timeline.png
fig20_simulation_scenarios.png	outputs/figures/fig20_simulation_scenarios.png
fig21_simulation_sensitivity.png	outputs/figures/fig21_simulation_sensitivity.png
fig22_ticket_classification_cm.png	outputs/figures/fig22_ticket_classification_cm.png
fig23_indicator_counts.png	outputs/figures/fig23_indicator_counts.png
fig24_risk_score_distribution.png	outputs/figures/fig24_risk_score_distribution.png
fig25_adversarial_tests.png	outputs/figures/fig25_adversarial_tests.png
fig26_architecture.png	outputs/figures/fig26_architecture.png
fig27_console_overview.png	outputs/figures/fig27_console_overview.png
fig28_console_accounts.png	outputs/figures/fig28_console_accounts.png
fig29_console_investigation.png	outputs/figures/fig29_console_investigation.png
fig30_console_simulation.png	outputs/figures/fig30_console_simulation.png

Table 36. Figures produced by the pipeline.

Key evidence files: outputs/tables/data_inventory.csv, data_dictionary.csv, cleaning_log.csv, eda_findings.csv, supervised_network_test.csv, anomaly_access_validation.csv, ueba_alerts.csv, incident_timeline.csv, incident_response_plan.csv, intel_operational_watchlist.csv, simulation_summary.csv, nlp_extracted_indicators.csv, risk_user_day_scores.csv, adversarial_results.csv, compliance_checklist.csv; plus outputs/intelligence_executive_brief.md and the documents in docs/.